ABNT NBR ISO 31000:2018

Gestão de riscos

UM GUIA PRÁTICO

UNITED NATIONS
INDUSTRIAL DEVELOPMENT ORGANIZATION

Documento protegido por direitos autorais
Todos os direitos reservados. A menos que especificado de outra forma, ou necessário no contexto de sua implementação, nenhuma parte desta publicação pode ser reproduzida ou utilizada de outra forma ou por qualquer meio, eletrônico ou mecânico, incluindo fotocópia, ou postagem na internet ou intranet, sem permissão prévia por escrito. A permissão pode ser solicitada tanto à ISO no endereço abaixo quanto ao órgão membro da ISO no país do solicitante.
© ISO 2021

Escritório de direitos autorais ISO
CP 401 • Ch. de Blandonnet 8
CH-1214 Vernier
Telefone: +41 22 749 01 11
Fax: +41 22 749 09 47
E-mail: copyright@iso.org
Site: www.iso.org
Publicado na Suíça

As opiniões expressas nesta publicação são de autoria e contribuidores e não refletem necessariamente as da ABNT ou da Organização das Nações Unidas para o Desenvolvimento Industrial (UNIDO). As designações empregadas e a apresentação de material não implicam a expressão de qualquer opinião por parte da ISO ou da Organização das Nações Unidas para o Desenvolvimento Industrial relativa ao status legal de qualquer país, território, cidade ou área, ou de suas autoridades; ou no que diz respeito à delimitação de suas fronteiras ou limites; ou seu sistema econômico ou grau de desenvolvimento. Designações como “desenvolvido”, “industrializado” e “desenvolvimento” destinam-se à conveniência estatística e não necessariamente expressam um julgamento sobre a etapa alcançada por um determinado país ou área no processo de desenvolvimento. A menção de nomes de empresas e organizações e seus sites, produtos comerciais, marcas ou processos licenciados não implica endosso pela ABNT ou Organização das Nações Unidas para o Desenvolvimento Industrial.

Sumário

Sumário 3
Prólogo 5
Prefácio Nacional 7
Introdução 9
ABNT NBR ISO 31000 *Handbook* orientativo 11
1. **Uso dos princípios da gestão de riscos da ABNT NBR ISO 31000** 11
2. **Liderança, comprometimento e responsabilidades** 13
3. **Estrutura de gestão de riscos** 24
4. **Processo de gestão de riscos** 37
5. **Eficácia do programa de gestão de riscos** 55
6. **Melhoria contínua** 59

Anexo A 63
Exemplo de análise de *gaps* (*gap analysis*) 63
Anexo B 65
Exemplo de categorias de risco 65
Bibliografia 68
Documentos ISO 68

Prólogo

Se risco é a combinação de oportunidades, ameaças e incertezas futuras, então gestão de riscos é uma disciplina essencial para a tomada de decisões informadas dentro de todas as organizações. Além disso, os últimos anos testemunharam todas as formas e escalas de riscos, sob o espectro de tamanhos e potenciais impactos; estes vão desde os desafios e oportunidades vistos na gestão cotidiana, até grandes eventos, como disrupções logísticas, agitação política, violações de dados em larga escala e bloqueios sem precedentes desencadeados por pandemias globais. Cada uma delas resultou em um maior reconhecimento e valorização do valor absoluto da gestão de riscos.

Todos os eventos, sejam grandes ou pequenos, podem ter um forte efeito sobre as organizações, empresas e mercados e economias em que operam. Devido às incertezas atuais, não é de surpreender quando as organizações lutam para identificar e gerenciar seus riscos. Gerenciar o risco de forma eficaz é como todas as organizações trazem maior grau de certeza a seu planejamento e atividades. Para atender a essa necessidade altamente relevante, a ABNT NBR ISO 31000:2018, *Gestão de riscos – Diretrizes*, foi projetada para auxiliar as organizações, fornecendo orientação e direção sobre como integrar uma estrutura eficaz para a tomada de decisão em sua governança, liderança e cultura. Organizações que gerenciam bem o risco não só sobrevivem, mas prosperam.

Como uma norma fundamental em gestão de riscos, a ABNT NBR ISO 31000 explica os conceitos fundamentais e princípios da gestão de riscos, descreve uma estrutura e delineia os processos de identificação e gestão de riscos. A ABNT NBR ISO 31000 é complementada pela ABNT NBR IEC 31010:2021, *Gestão de riscos – Técnicas para o processo de avaliação de riscos* e ABNT NBR ISO 31073, *Gestão de riscos – Vocabulário*. Estas duas normas contêm valiosas informações e orientações sobre técnicas de gestão de riscos, bem como os termos e definições. Para auxiliar ainda mais as organizações na implementação da gestão de riscos, é somada agora à família de normas a ABNT NBR ISO 31000:2018 – *Gestão de riscos – Um guia prático*.

Este *handbook* foi escrito a pedido do Comitê Técnico da ISO, ISO/TC 262, *Risk Management*, para fornecer um guia de implementação para a Norma de gestão de riscos, ISO 31000. O objetivo deste *handbook* é auxiliar as organizações que buscam orientações sobre como integrar a gestão de riscos em suas atividades. O *handbook* inclui, portanto, informações sobre os princípios de gestão de riscos, estrutura, papéis e responsabilidades, planejamento, processos, comunicação, monitoramento e análise crítica, e melhoria contínua. Este *handbook* foi escrito por especialistas do *Working Group* 6 do ISO/TC 262, *Risk Management*, para aqueles que estão começando sua jornada em gestão de riscos ou que requerem orientações adicionais sobre como melhorar seu programa atual de gestão de riscos.

Espera-se que este *handbook*, publicado em conjunto pela *International Organization for Standardization* (ISO) e pela Organização das Nações Unidas para o Desenvolvimento Industrial (UNIDO), apoie o esforço da sua organização na criação e proteção de valor com o auxílio da realização dos múltiplos benefícios oferecidos pela ABNT NBR ISO 31000.

Prefácio Nacional

Este *handbook* está alinhado com a ABNT NBR ISO 31000:2018, *Gestão de riscos – Diretrizes*. O objetivo é orientar as organizações para implementar e praticar a gestão de riscos. Por brevidade, este *handbook* se referirá a esta Norma como ABNT NBR ISO 31000. Este *handbook* é consistente com o conteúdo da ABNT NBR ISO 31000; contudo, ele não replica a estrutura da ABNT NBR ISO 31000.

A tradução deste *handbook* foi elaborada com o apoio da Comissão de Estudo Especial de Gestão de Riscos (ABNT/CEE-063) e publicada em 30.03.2023.

Convém que quaisquer comentários ou perguntas sobre este documento sejam direcionados à ABNT.

Introdução

A implementação de uma gestão de riscos eficaz apoia a qualidade e o sucesso e, potencialmente, o bem da sociedade.

A ABNT NBR ISO 31000 define risco como o efeito da incerteza sobre os objetivos. Estes podem incluir o propósito, a visão e os valores da organização, bem como os objetivos e metas articulados em diferentes níveis da organização. Também podem incluir os fatores que são importantes para uma determinada decisão.

A ABNT NBR ISO 31000 fornece uma abordagem comum para gerenciar qualquer risco e não é específica para uma indústria ou setor. Ela fornece orientações para auxiliar as organizações na integração de um programa de gestão de riscos eficaz em todas as suas atividades e funções.

Este *handbook* expande e fornece contexto para as seções da ABNT NBR ISO 31000. Ele fornece recomendações sobre a introdução e implementação da gestão de riscos, incluindo como criar e proteger valor para as partes interessadas. Este *handbook* demonstra como:

- Utilizar os princípios da gestão de riscos de forma eficaz e eficiente na maneira como o risco é gerenciado;
- Desenvolver um plano para integrar riscos nos arranjos existentes de uma organização;
- Entender como a cultura organizacional influencia a concepção e implementação da gestão de riscos;

- Confirmar que a necessidade de uma gestão de riscos eficaz seja considerada quando mudanças afetarem a organização;
- Aplicar o processo de gestão de riscos para identificar, analisar, avaliar e, quando necessário, tratar o risco;
- Comunicar e consultar as partes interessadas;
- Monitorar e analisar criticamente o plano e processo de gestão de riscos; e
- Melhorar continuamente, com base no contexto e nas lições aprendidas.

Assim como na ABNT NBR ISO 31000, este *handbook* pode ser usado para gerenciar riscos em todos os tipos de organizações. Ele é aplicável a uma organização e às suas atividades. Ele é aplicável às organizações que estão considerando implementar a ABNT NBR ISO 31000 ou buscar melhorias na gestão de riscos existente.

ABNT NBR ISO 31000
Handbook orientativo

1.1 Uso dos princípios da gestão de riscos da ABNT NBR ISO 31000

Os princípios da gestão de riscos ligam a estrutura e a prática de gestão de riscos aos objetivos e metas estratégicas da organização.

O princípio central e propósito da gestão de riscos é que cria e protege valor. Os princípios são fundamentais em todos os aspectos da gestão de riscos e foram incorporados ao longo das seções deste *handbook*.

A gestão de riscos é integrada: convém que os riscos sejam considerados durante as atividades regulares dos negócios e durante a tomada de decisão em toda a organização, e integrados com o sistema de gestão geral da organização.

Convém que os arranjos da gestão de riscos sejam estruturados e abrangentes: uma estrutura sistematizada auxilia a compreensão organizacional de papéis e responsabilidades, e fornece procedimentos consistentes. Estes incluem procedimentos para identificar, entender e tratar riscos e comunicar informações.

A gestão de riscos é personalizada: esse princípio incentiva as organizações a personalizar a gestão de riscos aos seus objetivos e necessidades.

A gestão de riscos é inclusiva: o engajamento oportuno e adequado das partes interessadas permite que uma ampla gama de pontos de vista seja considerada parte da gestão de riscos, resultando em decisões mais bem informadas.

A gestão de riscos é dinâmica: à medida que o contexto e as circunstâncias de uma organização mudam com o tempo, seus riscos também mudam. Esse princípio reforça que os riscos devem ser periodicamente analisados criticamente, para assegurar que estejam abordando os objetivos organizacionais.

Melhores informações disponíveis: a tomada de decisão informada requer informações relevantes e precisas da organização, bem como de outras fontes. Convém que a gestão de riscos reflita e considere as entradas de partes interessadas internas e externas.

Fatores humanos e culturais: a gestão de riscos envolve a colaboração e o engajamento das partes interessadas. Isto pode resultar na compreensão dos fatores humanos e culturais mais importantes para o sucesso organizacional. Esse princípio também se refere a considerar circunstâncias únicas e necessidades humanas ao integrar a gestão de riscos na organização e ao desenvolver processos adequados de gestão de riscos.

Melhoria contínua: este princípio incentiva uma organização a monitorar, analisar criticamente e melhorar continuamente os processos de gestão de riscos, para assegurar sua pertinência, eficiência e eficácia no apoio ao desempenho geral da organização.

1. Liderança, comprometimento e responsabilidades

1.1 Visão geral

A gestão de riscos agrega e protege valor, permitindo que as organizações alcancem seus objetivos de forma mais eficaz e eficiente, e com maior certeza a longo prazo. As organizações que continuam a ter sucesso são aquelas com capacidade de prever e se preparar para os riscos.

A implementação e o aprimoramento da gestão de riscos apoiam os objetivos de uma organização, bem como cria e protege valor para a organização. A implementação começa com a compreensão do que significa valor para a organização. O valor da gestão de riscos é expresso em muitos termos, como participação de mercado, lucro, gestão de serviços, entrega de projetos ou serviços sociais. Nenhum modelo único de gestão de riscos atinge essas metas. Cada organização é responsável pela identificação do valor, que depende diretamente da missão, da visão, dos objetivos estratégicos e das atividades primárias da organização.

O valor da gestão de riscos é patrocinado pelo órgão de supervisão da organização, colocado em prática pela Alta Direção e pelos proprietários

de riscos, e aplicado a toda a organização por meio de uma estrutura comum. Essa estrutura pode variar muito entre as organizações, mas normalmente envolve liderança e comprometimento, recursos e responsabilizações, comunicação, planos, ações e processos definidos.

1.2 Papel da gestão de riscos na tomada de decisões

1.2.1 Geral

A chave para gerenciar eficazmente uma organização e criar valor é a tomada de decisão informada, lógica, estruturada e consistente. Para pesar diferentes opções na busca de seus objetivos e resultados desejados, os tomadores de decisão selecionam entre escolhas baseadas na experiência, razão e melhor informação disponível. O processo de gestão de riscos fornece uma base para a tomada de decisão informada para determinar um curso ou cursos de ação. A gestão de riscos é uma disciplina de tomada de decisão que deve ser integrada a todos os aspectos de uma organização. O método selecionado para avaliar os riscos pode auxiliar o tomador de decisão a tomar uma decisão informada. A tomada de decisões é parte fundamental da gestão estratégica e operacional, bem como dos controles de uma organização bem gerenciada.

A boa tomada de decisão baseia-se em uma compreensão clara do contexto e das incertezas subjacentes no alcance dos objetivos. As organizações enfrentarão vários riscos, sendo alguns com efeitos compostos ou em cascata. Tanto a natureza dos riscos individuais quanto a dos riscos de interação podem ser identificadas e compreendidas para apoiar a tomada de decisões informadas e reconhecer melhor o potencial não intencional das consequências de decisões. Desenvolver e avaliar cenários alternativos reduz a incerteza na tomada de decisões e ilumina as incógnitas que podem ocorrer. Os prazos e a extensão do impacto na organização determinam a criticidade dos processos de tomada de decisão.

EXEMPLO – Estudo de caso

Para que seus produtos sejam comercializados de forma segura e lucrativa, uma empresa de refinarias de petróleo precisa entender os problemas relacionados ao *design* físico, operações, segurança, meio ambiente, qualidade, reputação, regulação, cadeia de suprimentos e economia, e as interações entre eles.

Para ser eficaz, a gestão de riscos precisa ser entendida no contexto da governança, conformidade, processos e procedimentos operacionais de uma organização. Para que as organizações alcancem seus objetivos estratégicos e operacionais, a gestão de riscos deve estar alinhada com as estruturas de governança, missão, valores e cultura da organização.

Para que uma organização prospere e seja sustentável, gerenciar a incerteza para alcançar os objetivos estratégicos e operacionais da organização é uma parcela integrante de todos os objetivos, atividades, funções e processos da organização. É uma abordagem de cima para baixo e de baixo para cima. Portanto, a tomada de decisão pode ser claramente compreendida e alavancada ao se estabelecer uma estrutura de gestão de riscos.

1.2.2 Integração dos riscos na tomada de decisão

Pode-se considerar que uma decisão tem três etapas: uma fase de pré-decisão, uma etapa de decisão ativa e uma etapa pós-decisão. A gestão de riscos pode ser integrada nas três etapas. Por exemplo, o risco pode ser avaliado antes para se decidir em seguir com uma iniciativa. Durante a fase de decisão ativa, o risco é considerado no contexto da definição de expectativas quanto à aceitação da perda e maximização do ganho. Após a decisão, podem ser avaliados e tratados os riscos decorrentes da implementação e estratégia.

Às vezes, as decisões simplesmente fluem de evidências disponíveis e confiáveis, quando os possíveis resultados são previsíveis e prováveis. Outras vezes, as decisões são tomadas em condições incertas, em que o estado atual de informações é tal que:

- A ordem ou a natureza das coisas são desconhecidas;
- As consequências, extensão ou magnitude das circunstâncias, condições ou eventos são imprevisíveis;

- As probabilidades críveis a possíveis resultados são imprecisas, na melhor das hipóteses;
- As situações dinâmicas e de rápida pressão afetam as suposições; e
- As informações disponíveis podem ser ambíguas ou incompletas.

A integração de considerações de incerteza na tomada de decisão pode levar a melhores decisões e melhores resultados. Para integrar os riscos na tomada de decisão, é necessário entender:

- Quem são os tomadores de decisão individuais;
- Quem é responsabilizado pela implementação das decisões;
- As atitudes de risco das pessoas em questão;
- A importância e a relevância da decisão;
- A implicação da decisão para várias partes da organização; e
- Os recursos disponíveis para cumprir a decisão.

Outras considerações fundamentais são a importância e a relevância da decisão, e as implicações da decisão sobre várias partes da organização.

1.3 Benefícios da gestão de riscos

Uma gestão eficaz de riscos permite que uma organização atinja seus objetivos, avaliando continuamente os riscos para reduzir surpresas e melhorar o seu desempenho. A gestão de riscos também fornece às partes interessadas relevantes informações contínuas, consistentes e confiáveis. Benefícios adicionais da implementação e integração de processos para gerenciar riscos em uma organização incluem:

- Um uso e alocação mais eficiente de capital e outros recursos;
- A capacidade de reconhecer e capturar oportunidades e ameaças rapidamente, e responder a elas;
- Uma redução na probabilidade e no impacto da perda;
- Decisões mais claras e bem informadas;
- Menores custos de conformidade/auditoria;
- Economia de custos com o uso de informações de risco para simplificação e melhoria de processos;
- Melhor gestão dos aspectos humanos e culturais que afetam o desempenho; e

Uma maior compreensão dos eventos potenciais e da capacidade de influenciar seus resultados.

1.4 Integração da gestão de riscos com a estratégia organizacional

1.4.1 Visão geral

Todas as decisões e atividades de uma organização envolvem riscos, começando pela estratégia. A integração de riscos e estratégias permite que a gestão selecione as melhores estratégias e gerencie os riscos relevantes. As subseções a seguir ilustram os passos que integram a gestão de riscos no desenvolvimento de estratégias.

1.4.2 Comunicação e consulta

A consulta às partes interessadas é importante no desenvolvimento de uma estratégia, de forma a fornecer informações para identificar riscos e obter apoio para os planos resultantes. Diálogos e discussões sobre estratégia são oportunidades para se chegar a uma visão consensual dos riscos enfrentados pela organização.

A comunicação e consulta adequadas às partes interessadas ocorrem no início e em todo o planejamento estratégico, em que uma entrada adicional melhoraria a compreensão de riscos ou confiança nas ações resultantes.

1.4.3 Estabelecimento do contexto estratégico

No desenvolvimento da estratégia, a Alta Direção pode considerar o atual contexto interno e externo, o desempenho passado e a visão para o curto, médio e longo prazos (ver 3.4.1 *Entender e usar o contexto organizacional*). A integração da gestão de riscos ao planejamento estratégico requer uma compreensão profunda dos principais impulsionadores de negócios, das necessidades e objetivos da organização e de como eles podem mudar com o tempo.

1.4.4 Identificação dos riscos associados à estratégia

À medida que as organizações desenvolvem estratégias, elas consideram oportunidades e ameaças, e os riscos associados a estas.

Ao determinar riscos estratégicos, a organização pode considerar elementos como riscos de longo e curto prazos, bem como riscos atuais e emergentes. Os riscos associados à estratégia abrangem múltiplos elementos de uma organização e sua capacidade de alcançar objetivos.

EXEMPLO

A crise climática está contribuindo para o aumento de eventos climáticos extremos, que podem impactar a durabilidade das estruturas, a confiabilidade da produção, a interrupção de viagens etc. Esses impactos podem afetar a gestão do ciclo de vida dos ativos e a projeção de custos e retornos operacionais..

1.4.5 Avaliação dos riscos da estratégia

Avaliar os riscos associados à estratégia é um processo iterativo. Os riscos são avaliados durante a seleção da estratégia, bem como posteriormente, para identificar e analisar os riscos com mais detalhes. As avaliações envolvem coleta e análise de informações, consulta às partes interessadas e aos especialistas, e uso de técnicas como as identificadas na ABNT NBR IEC 31010:2021, *Gestão de riscos – Técnicas para o processo de avaliação de riscos.* Entrevistas com órgãos da Alta Direção e supervisão permitem discussões e consideração de riscos para a estratégia potencial, incluindo riscos emergentes.

1.4.6 Finalização do plano, incluindo as ações de tratamento para os riscos identificados

O plano de implementação da estratégia deve incorporar o tratamento dos riscos identificados. A estratégia precisa ser integrada e comunicada a todos os níveis da organização.

1.4.7 Monitoramento e análise crítica dos riscos e objetivos estratégicos

Os riscos, os objetivos estratégicos e as principais medidas de desempenho de risco (ver *Seção 6 Melhoria contínua*) devem ser monitorados como parte das análises críticas regulares.

1.5 Atribuição de papéis e responsabilidades

1.5.1 Visão geral

Para ter sucesso, a gestão de riscos requer total apoio da Alta Direção (definida como membros de equipes executivas seniores) e de órgãos de supervisão (mais comumente o conselho). A Alta Direção é, em última análise, responsável pela gestão de riscos de uma organização e de seus sucessos e fracassos. A responsabilização pela gestão de riscos é um aspecto importante da governança dentro da organização. Uma estrutura de governança de riscos inclui uma compreensão clara de papéis, responsabilidades, responsabilizações e supervisão. A clara articulação das responsabilizações para gestão de riscos em todos os níveis apoia uma compreensão completa dos papéis e responsabilidades. As seguintes subseções (ver 2.5.2 a 2.5.6) apresentam papéis para gerenciar riscos em uma organização.

1.5.2 Órgãos de supervisão

Conselhos ou órgãos de supervisão têm um papel vital em nome das partes interessadas para assegurar que a organização esteja gerenciando os riscos que enfrenta adequadamente. As responsabilidades do órgão de supervisão em relação aos riscos incluem:

- Supervisionar a cultura que apoia a gestão de riscos dentro da organização e como os incentivos impulsionam esse apoio;
- Definir a quantidade e os tipos de riscos que uma organização pode correr, em conjunto com a Alta Direção;
- Manter a supervisão de riscos e controles que podem impactar os objetivos da organização;
- Tomar medidas para assegurar que a linguagem usada para se comunicar sobre riscos e sua gestão seja clara e compreendida em toda a organização;

- Assegurar que a gestão de riscos esteja inserida em processos que apoiem decisões importantes; e
- Determinar uma estrutura adequada para a garantia da gestão de riscos, incluindo o papel dos comitês de auditoria e de riscos.

EXEMPLO – Estudo de caso

No exemplo de uma pequena organização familiar, em alguns casos, o conselho é composto pelos proprietários e pela Alta Direção, como os gerentes de finanças e operações.

No caso de uma startup sem fins lucrativos, inicialmente, o conselho pode incluir colegas profissionais, parceiros e voluntários. À medida que a organização sem fins lucrativos ganha uma maior compreensão de seu contexto, objetivos estratégicos e riscos, podem surgir requisitos para novas habilidades da diretoria e experiência em jurídico, marketing e captação de recursos.

1.5.3 Alta Direção

Seja como um processo formal ou informal, todas as organizações gerenciam os riscos.

A Alta Direção precisa demonstrar um compromisso com a gestão de riscos que enfatize sua importância, integração e eficácia em toda a organização. As responsabilidades da Alta Direção são:

- Entender o ambiente de riscos dinâmico em que a organização atua;
- Ter uma visão geral dos riscos dentro da organização;
- Estabelecer e comunicar uma política de gestão de riscos internamente e às partes interessadas, conforme apropriado;
- Assegurar que a gestão de riscos esteja alinhada com a estratégia e os objetivos da organização;
- Exemplificar e modelar ativamente como considerar os riscos na tomada de decisões, seguindo os mesmos processos esperados do resto da organização;
- Estabelecer a quantidade de riscos que a organização está disposta a correr em busca de objetivos;
- Alocar recursos para implementar, monitorar e melhorar a gestão de riscos em toda a organização;
- Assegurar a implementação de uma estrutura de gestão de riscos e de processos;

- Incentivar as pessoas a verem positivamente a identificação, a análise e o tratamento de riscos; e
- Gerenciar os riscos que possuem.

1.5.4 Partes interessadas

Uma parte interessada é uma pessoa ou organização que pode afetar, ser afetada ou perceber-se afetada por uma decisão ou atividade (ver ABNT NBR ISO 31000). As partes interessadas podem ter a oportunidade de fornecer sua perspectiva e considerá-la, mesmo que não esteja alinhada com a perspectiva da organização.

As partes interessadas externas podem incluir:

- Acionistas que esperam um retorno de seu investimento e desempenho contínuo dos resultados;
- Clientes afetados pela qualidade dos produtos e serviços;
- Fornecedores e parceiros que esperam um relacionamento duradouro e confiável;
- Governo (níveis nacional e local), sindicatos, organizações não governamentais; e
- Público, que depende do desempenho econômico e ambiental da organização, da sua reputação e do cumprimento das obrigações legais e regulatórias.

As partes interessadas internas incluem funcionários, todos os níveis de gestão e outros envolvidos na gestão de riscos eficaz. Responsabilidades específicas incluem:

- Estar ciente e cumprir suas responsabilidades conforme definido pela estrutura de gestão de riscos;
- Fornecer entradas em atividades de gestão de riscos;
- Participar de procedimentos e processos de gestão de riscos para identificar e analisar riscos;
- Assegurar que os tratamentos dos riscos sejam eficazes dentro de sua área de responsabilização;
- Notificar riscos; e
- Seguir políticas e procedimentos para assegurar o compliance.

Às vezes, pode haver uma sobreposição entre as partes interessadas externas e internas, por exemplo, acionistas.

1.5.5 Proprietários de risco

Um proprietário de risco é uma pessoa ou uma entidade com a responsabilização e autoridade para gerenciar riscos. A cultura e a estrutura da organização desempenham um papel fundamental na determinação do melhor modelo para atribuir proprietários de risco.

Os proprietários de risco devem ter o nível adequado de autoridade de tomada de decisão para gerenciar seus riscos atribuídos.

A propriedade do risco pode ser delegada por meio de vários níveis da organização. Isso auxilia na redução da carga horária na Alta Direção, bem como no cultivo do pensamento, comportamentos e ações sobre riscos e gestão de riscos em toda a organização.

EXEMPLO

O proprietário de risco pode estar em qualquer nível da organização, por exemplo, um gerente de projeto responsável por um projeto específico ou um gerente de processo responsável pelo orçamento e recursos para uma linha de produção em uma fábrica.

Para os proprietários de risco, é requerido o seguinte:

- Um bom conhecimento e uma compreensão de sua área de risco;
- Nível adequado de autoridade de tomada de decisão dentro da organização;
- Acesso a recursos como pessoas e/ou orçamento;
- Treinamento adequado em gestão de riscos; e
- Conhecimento e compreensão das principais partes interessadas.

1.5.6 Líderes de risco

Os líderes de risco são responsáveis por assegurar a implementação e integração de uma estrutura e processo de gestão de riscos no sistema e nos processos de gestão da organização.

Às vezes são referidos como campeões de risco ou coordenadores. Eles possuem conhecimento e compreensão dos riscos, e fornecem a capacidade de facilitar o processo de risco. Em algumas organizações, isso pode envolver a concepção e personalização da estrutura e o desenvolvimento de ferramentas e orientações adequadas para suportar outras pessoas em suas responsabilidades de gestão de riscos.

Para os líderes de risco é requerido:

- Treinamento adequado em gestão de riscos;
- Uma boa compreensão da missão, propósito e objetivos da organização e do ambiente em que se atua;
- Um entendimento da organização, incluindo a estrutura de governança, operações, mercados, receita e fontes de financiamento, tecnologia e pessoas; e
- A capacidade de se comunicar eficazmente e fomentar a gestão de riscos nas atividades cotidianas.

1.6 Comprometimento da liderança com a gestão de riscos

Uma gestão de riscos eficaz fornece à Alta Direção informações e insights para conduzir a organização, tomar decisões informadas e alcançar objetivos, assumindo os riscos certos.

Questões que demonstram o comprometimento dos líderes incluem:

- A gestão de riscos é apoiada pela Alta Direção?
- São considerados riscos relevantes em decisões e ações?
- O risco é discutido em todos os níveis da organização?
- Existem recursos apropriados destinados à gestão de riscos em toda a organização?
- Os proprietários de risco identificaram seus riscos e entendem como gerenciá-los?
- Os riscos apropriados são escalados para a Alta Direção em tempo hábil?
- Existe uma função de risco ou líder de risco dentro da organização?
- O líder de risco tem uma linha direta de subordinação à Alta Direção e aos órgãos de supervisão?
- As funções e responsabilidades de relatos são atribuídas?
- Os órgãos de supervisão estão engajados em tempo hábil em questões significativas de risco, particularmente os principais riscos estratégicos?
- Os órgãos de supervisão entendem seu papel na gestão de riscos?
- Os órgãos de supervisão avaliaram a eficácia dos processos de supervisão?
- Os órgãos de supervisão estão recebendo os relatos de riscos e informações de que precisam?

2. Estrutura de gestão de riscos

2.1 Introdução

Liderança, comprometimento e responsabilidades claramente definidos são necessários para realizar a melhor tomada de decisão e para haver menos surpresas, mas não são suficientes para transformar gestão de riscos em ações. O propósito de uma estrutura de gestão de riscos é auxiliar a organização na integração da gestão de riscos em atividades e funções importantes. Esta seção fornece orientações sobre como desenvolver e melhorar continuamente uma estrutura personalizada para integrar e sustentar a gestão de riscos em uma organização. Esta atividade fundamental ajuda a integrar a gestão de riscos nos arranjos de governança e gestão existentes, e a melhorar continuamente as atividades de gestão de riscos.

Uma estrutura de gestão de riscos inclui contexto, políticas, recursos, processos, estrutura organizacional e técnicas necessárias para implementar a gestão de riscos em uma organização. A personalização de uma estrutura dinâmica ajuda a organização a integrar a gestão de riscos em arranjos de governança, tomadas de decisões, processos e atividades relacionadas.

2.2 Fornecimento de justificativa para a gestão de riscos

Os líderes designados e responsabilizados precisam desenvolver uma justificativa para implementação ou melhoria da gestão de riscos. Isso requer uma sólida compreensão da visão, da missão e dos objetivos da organização e do ambiente em que ela opera, bem como da estrutura da organização e como a gestão de riscos criará e protegerá valor.

Preparados com a compreensão da missão, do modelo de negócios e do meio ambiente de uma organização, os líderes responsáveis por projetar uma estrutura vão se beneficiar pela confirmação do comprometimento da Alta Direção para integrar e assumir a responsabilização por gerenciar riscos. A consulta com a Alta Direção fornece uma base para a justificativa de implementar ou melhorar os recursos e práticas de gestão de riscos. A consulta pode incluir a discussão das expectativas sobre o que a gestão de riscos pode proporcionar aos líderes individuais e à organização.

Projetar uma estrutura de gestão de riscos "adequada" envolve entender como a organização cria, entrega, captura e protege valor. Por exemplo, o projeto pode incluir a investigação e o entendimento de seu propósito, estratégia, objetivos, processos de tomada de decisão, práticas atuais de gestão de riscos, necessidades e resultados desejados. A integração dos princípios de gestão de riscos da ABNT NBR ISO 31000 no desenho da estrutura pode ajudar as organizações a se concentrarem no porquê a gestão de riscos é importante.

Fazer perguntas como "Como estamos gerenciando o risco atualmente?" e "Qual resultado queremos alcançar que atualmente não estamos alcançando?" pode ajudar a determinar a justificativa de mudança para melhorar as práticas de gestão de riscos da organização. As abordagens podem diferir, dependendo do que é necessário e de como os objetivos de gestão de riscos da organização podem ser suportados dentro das atuais organizações de governança ou se esses arranjos podem ser modificados.

Uma maneira de desenvolver uma justificativa e obter comprometimento é desenvolver uma mensagem clara, concisa e convincente sobre o valor esperado a partir da estratégia de risco, no que se refere aos objetivos organizacionais específicos. Então, uma prévia do caso de negócios envolvendo os principais

tomadores de decisão e influenciadores pode refinar a justificativa e a necessidade dos negócios.

EXEMPLO

Os objetivos organizacionais podem ser:

- resultados específicos (resultados positivos de um projeto: apoiar um aumento de 10 % em novos clientes altamente qualificados ou avaliar riscos associados a planos de incentivo a vendas);
- apoiar objetivos mais gerais (para melhorar as chances de alcançar e manter um aumento de 10 % no crescimento da receita, avaliar os riscos associados aos mercados-alvo e melhorar as competências de risco); ou
- objetivos baseados em processos (avaliar e relatar desvios positivos e negativos do risco que a organização pode ou não assumir em uma carteira de bolsas).

2.3 Definição do caso de negócios

Um caso de negócios para a gestão de riscos descreve as opções e fornece a abordagem recomendada para seguir adiante. Esse caso de negócios pode incluir o seguinte:

- Resumo executivo
  - Reconhecimento formal e autoridade individual para gerenciar a integração
  - Propósito do programa e necessidade de negócios
  - Prioridade do programa
    - Prioridade estratégica, no nível de conselho
    - Benefícios específicos a serem adquiridos
- Declaração e Definição do Escopo do Programa
  - Lista de objetivos e entregas esperadas
  - Descrição do trabalho
  - Lista de premissas e restrições
  - Cronograma estimado e medidas-alvo de recursos, datas/marcos
  - Solicitações de capital e despesas operacionais
  - Principais recursos internos e externos necessários, horas de trabalho estimadas
  - Medição de desempenho e critérios
- Papéis e Responsabilidades do Programa
  - Patrocinador executivo, líder do programa, gerente de projetos e lista de partes interessadas com autoridade e responsabilizações para cada.

Convencer os principais tomadores de decisão do valor da gestão de riscos pode torná-los adotantes iniciais e campeões da gestão de riscos em toda a organização.

2.4 Desenvolvimento de uma estrutura adequada

Uma estrutura adequada ajuda a integrar as atividades de gestão de riscos nos arranjos de gestão e governança existentes, e a melhorar continuamente a gestão de riscos. Para construir ou atualizar uma estrutura, é necessário considerar como o risco já é gerenciado na organização.

A formalização de uma estrutura na organização geralmente incorpora uma avaliação das práticas de gestão de riscos existentes para identificar gaps, fazer melhorias e criar consistência. Essa avaliação pode se concentrar em práticas, bem como em pessoas, processos e tecnologia.

As práticas de gestão de riscos existentes podem ser identificadas analisando criticamente políticas, práticas, relatórios e atividades de operações-chave, departamentos ou locais. Outros métodos incluem entrevistas com pessoal-chave, observações pessoais e pesquisas.

Depois de documentar e entender as práticas e atividades de gestão de riscos, é possível compará-las para consistência e eficácia. Na medida que gaps são identificados, planos podem ser feitos para melhorar, preencher gaps ou reduzir os esforços que não sejam adequados às necessidades de uma área ou de toda a organização. Esse processo pode identificar áreas que utilizam mais recursos do que o necessário, bem como deficiências.

2.4.1 Entender e usar o contexto organizacional

Os elementos do contexto organizacional descritos na ABNT NBR ISO 31000 destinam-se a ser abrangentes. A personalização auxilia no alinhamento dos elementos às estruturas e propósitos organizacionais específicos. Informações adicionais relevantes para a estrutura incluem a estrutura da própria organização, que pode ser clara por meio de um organograma, ou uma lista dos principais serviços ou departamentos, filiais e locais.

Uma abordagem para articular os contextos interno e externo é redigir descrições de cada elemento. Tomadas como um todo, as descrições fornecem clareza sobre como criar uma estrutura consistente e sustentável para a gestão de riscos em toda a empresa. Descrições de contextos interno e externo também podem revelar áreas de risco que valem a pena ser perseguidas ou podem precisar de extrema cautela. Uma compreensão completa do contexto organizacional pode resultar na coleta de informações importantes.

EXEMPLO – Estudo de caso

Durante uma discussão sobre o contexto das operações, o comitê de risco da universidade identificou várias leis e regulamentações que requerem uma adesão rigorosa (um elemento de contexto externo). A universidade tem vários departamentos internos afetados por essas leis e regulamentações, com pouca comunicação entre eles. Portanto, o relato às vezes é duplicado e sempre ineficiente (um elemento do contexto interno). Esse arranjo organizacional também cria o risco de que informações conflitantes podem resultar em um escrutínio aprofundado por parte das agências reguladoras, sanções ou má publicidade. Como resultado dessas informações, uma estrutura foi estabelecida com a supervisão centralizada desses principais riscos. Os processos de relato e governança foram melhorados. A discussão do contexto também identificou um risco fundamental que precisava ser gerenciado.

Outro exemplo, de uma empresa de *startup* de alta tecnologia:

O fundador da empresa e um pequeno número de colaboradores utilizaram os elementos dos contextos interno e externo como *checklist* à medida que desenvolveram suas estratégias de implementação e marketing. Também incorporaram o contexto organizacional e a consideração de riscos nas decisões sobre projetos. Por isso, integraram sua estrutura de gestão de riscos diretamente nos processos de tomada de decisão e planejamento.

Uma compreensão do contexto organizacional ajuda a personalizar e integrar uma estrutura de gestão de riscos para que seja aceita dentro da organização.

2.4.2 Treinar a equipe

Um dos pré-requisitos para uma gestão de riscos eficaz é que todos dentro da organização entendam seu papel e responsabilidades em relação à gestão de riscos. O desenvolvimento de uma estrutura requer decisões incluindo:

- Como a gestão de riscos é estruturada (uma estrutura);
- Como as pessoas são informadas e engajadas (pelo plano e pelos processos de gestão de riscos); e

- Como os processos de gestão de riscos são implementados e relatados (um elemento do plano de gestão de riscos).

Para organizações de qualquer porte ou complexidade, essas são decisões que requerem participação e entradas em grupo.

As organizações podem estruturar as funções de planejamento e supervisão usando a governança compartilhada para incorporar múltiplos pontos de vista e conhecimento da organização. A organização precisará avaliar e resolver continuamente quaisquer *gaps* no conhecimento dos indivíduos do grupo. A justificativa para a gestão de riscos, a compreensão do contexto e a consideração das partes interessadas podem informar a estrutura e o processo de governo da organização.

EXEMPLO – Estudo de caso

Um grande governo urbano de um município criou um Comitê Consultivo de Gestão de Riscos Corporativos de uma dúzia de líderes representando todas as divisões dentro da organização.

Os membros do comitê servem por mandatos de três anos; o comitê se reúne trimestralmente. O trabalho do comitê começou com a educação de seus membros sobre o propósito, o valor e os resultados da gestão de riscos. O comitê, então, trabalhou os elementos de uma estrutura de gestão de riscos, incluindo a determinação de definições, finalidade e processo comuns. O comitê documentou sua descrição do contexto das operações e das partes interessadas internas e usou essas informações para desenvolver o plano de implementação de gestão de riscos de vários anos do município. Essas descrições também foram integradas em todos os processos de gestão de riscos. Os membros do comitê desenvolveram competências e experiência e puderam auxiliar os departamentos na aplicação do processo de gestão de riscos a decisões e projetos. À medida que os riscos foram identificados e os planos de tratamento desenvolvidos, o comitê forneceu supervisão sobre os principais riscos. O comitê continua a reportar ao conselho de administração sobre os principais riscos, progressos e desafios.

2.4.3 Considerar fatores críticos de sucesso

Fatores críticos de sucesso são os elementos necessários para alcançar missão ou propósito. Eles são indicadores de oportunidades, atividades ou condições necessárias para alcançar os resultados desejados, portanto, são específicos para cada organização. Fatores críticos de sucesso podem ser físicos (como linhas de produção ou capacidades de cadeia de suprimentos) ou não físicos (habilidades,

mercados ou reputação). Às vezes são descritos por meio de escala, velocidade e dependência.

Exemplos de perguntas relacionadas aos fatores críticos de sucesso incluem:

- A pontualidade ou a velocidade é um elemento de qualquer fator de sucesso crítico?
- Há diferenças de escala que afetem os elementos críticos?
- Quais dependências e interdependências afetam os objetivos?
- Quais parâmetros quantitativos e qualitativos são necessários para serem compreendidos e alcançados?
- Quais mudanças podem afetar a realização de objetivos atuais ou futuros?
- Como os fatores críticos são monitorados e medidos?
- O que pode dar errado, e o que precisa dar certo?

EXEMPLO – Estudo de caso

Uma rede global de hotéis está considerando vender locais para cobrir dívidas. Alguns dos fatores críticos de sucesso incluem a quantidade de tempo existente para resolver seus problemas financeiros, as razões pelas quais a organização não é capaz de cobrir a dívida com o fluxo de caixa de fontes operacionais, e se a alienação tem implicações para a marca e reputação do hotel. Uma pequena *startup* de alta tecnologia com foco na gestão de oportunidades, no início do interesse dos investidores, depende criticamente do sucesso da captação de recursos por meio de investimentos e desenvolvimento de oportunidades para levantar capital necessário. Os fatores de sucesso crítico se concentrarão nos pontos fortes e fracos da *startup* aos olhos de investidores e gestores de bancos.

Considerar fatores críticos de sucesso na tomada de decisões e durante o processo de gestão de riscos pode:

- Maximizar as consequências positivas e minimizar as consequências negativas de eventos ou tendências que possam ocorrer;
- Maximizar o uso de recursos limitados, incluindo o tempo;
- Melhorar a eficiência e a eficácia; e
- Ajudar a priorizar riscos e implantar recursos em proporção às estratégias e objetivos da organização.

A construção de uma estrutura para um programa de gestão de riscos bem-sucedido e adequado requer uma ampla compreensão, planejamento e abordagem colaborativa para alcançar as metas de gestão de riscos da organização.

O desenvolvimento de um plano para introduzir ou aprimorar a gestão de riscos baseia-se no caso de negócios, contexto organizacional, nível de comprometimento de liderança, resultados da análise de *gaps*, objetivos e expectativas organizacionais.

2.4.4 Conceituar um plano de gestão de riscos

Um plano de gestão de riscos ajuda uma organização a melhorar e integrar a gestão de riscos. O plano articula a visão da organização para a gestão de riscos, explicando o conceito de gestão de riscos da organização em seu futuro estado. Elementos do caso de negócios formal informam essa visão, incluindo a justificativa, o propósito do programa e a necessidade dos negócios.

O propósito de uma declaração de visão de risco é definir por que e como o risco pode ser gerenciado na organização e a estratégia para evoluir a gestão de riscos, ao longo do tempo. Podem ser incluídas descrições de quem estaria envolvido, como o risco seria comunicado e gerenciado em toda a organização, e expectativas de responsabilização e tomada de decisão. Definir a e comunicar continuamente essa visão ajuda a focar e organizar o plano de gestão de riscos.

2.5 Avaliação do estado atual das práticas de gestão de riscos

A melhoria das práticas atuais começa pelo entendimento de como o risco é gerenciado atualmente, dos programas de risco atualmente implementados e onde a organização já desenvolveu sistemas ou processos para gerenciar o risco. Embora uma variedade de técnicas possa ser usada, uma simples análise de *gaps* busca responder às perguntas “onde estamos?” (o estado atual) e “onde queremos estar”? (o estado futuro). Um inventário da gestão de riscos e uma análise de *gaps* com base nos critérios acordados e nos arranjos da organização podem ser usados para analisar o estado atual.

As perguntas para avaliar as práticas atuais de gestão de riscos incluem:

- Como a sua organização mede e gerencia riscos nesta área, em departamento ou em atividades específicas?
- Quem é responsabilizado pelos processos e resultados de gestão de riscos?

- Quais políticas e procedimentos existem atualmente para gerenciar riscos e são adequadamente comunicados?
- Como as pessoas consideram, agem e reportam riscos?
- Quais dados de risco são coletados e reportados?
- Quem é responsável pela exatidão, manutenção e emissão de relatórios de dados de risco?
- Existem outros programas ou requisitos de conformidade que envolvam a gestão e a notificação de riscos?
- A cultura incentiva uma discussão aberta sobre riscos?
- As técnicas de avaliação de risco são usadas adequadamente?

O envolvimento das principais partes interessadas experientes no desenvolvimento dos critérios de desempenho da análise de *gaps*, avaliação do estado atual e determinação do estado futuro desejado demonstra os princípios de gestão de riscos de inclusão, integração e personalização.

As partes interessadas precisam concordar com práticas fundamentais de gestão de riscos que são importantes para a organização. Convém que alista dos fatores necessários para alcançar o estado futuro desejado (o que será), como finanças, pessoas, processos ou tecnologia, seja baseada em discussões incorporando o resultado da gestão de riscos da organização. As discussões com as partes interessadas destacam a quantidade do quanto a necessidade excede os recursos existentes e quais *gaps* devem ser preenchidos para serem bem-sucedidas (o que considerar). Ver o **Anexo A** para exemplo de uma análise de *gaps*.

As provas utilizadas para a análise das práticas de risco existentes devem ser registradas.

EXEMPLO – Estudo de caso

Uma organização governamental de grande porte exige que os auditores internos completem a educação continuada em avaliações de desempenho de gestão de riscos em seus planos anuais de desenvolvimento pessoal, para resolver gaps no conhecimento. A documentação dos créditos da educação continuada fornece evidências relacionadas ao treinamento de avaliação de risco do pessoal.

Em organizações de médio e grande portes, uma estrutura de risco exige que o comitê de risco se reúna uma vez por trimestre. Para resolver gaps na governança, a ata dessas reuniões fornece evidências, incluindo quem comparece, quantas vezes são realizadas, o que é discutido e se as ações são encerradas dentro do prazo original.

Quando necessário, as organizações podem estabelecer declarações de apetite de risco ou estratégias, em termos quantitativos ou qualitativos, para expressar vontade de perseguir ou reter riscos para alcançar a missão, a estratégia ou um objetivo específico. Tais declarações podem ser exigidas por reguladores, prioridades de gestão ou prática do setor, e podem ser consideradas na avaliação do estado atual. Organizações que não estabeleceram seu apetite de risco formal ou informal podem concordar se tais declarações podem ser úteis como parte de um estado futuro desejado.

Obtenção de consenso para a justificativa de modificar e melhorar as práticas existentes fornece a base para o desenvolvimento de uma estrutura e a formulação de um plano realista de gestão de riscos.

2.6 Criação de um plano de gestão de riscos

Um plano de gestão de riscos detalha as etapas necessárias para estabelecer ou melhorar os recursos de gestão de riscos de uma organização. Um plano de gestão de riscos assegura que as atividades ocorram em uma ordem coerente e fornece um meio de registrar o progresso e acompanhar a melhoria.

O engajamento de um amplo grupo de parte interessadas com diversas responsabilidades no desenvolvimento do plano pode fornecer uma visão mais abrangente dos resultados desejados e incentivar uma melhor adoção. Também pode ajudar uma organização a antecipar e lidar proativamente com possíveis complicações e outras questões.

A organização do plano em etapas pode permitir o acompanhamento de objetivos imediatos, de médio e longo prazos. Isso prepara o cenário para alcançar resultados rápidos e mensuráveis, mas também estabelece expectativas realistas de que a integração total pode ser um processo de longo prazo. A integração desses objetivos do plano com outras atividades de melhoria organizacional reforça a gestão de riscos como um componente fundamental da eficácia operacional, e não como uma atividade separada. Assim como em outros aspectos da gestão de riscos, aproveitar todas as oportunidades para alavancar os relatórios e a infraestrutura operacional existentes. Avaliar e gerenciar riscos

para a implementação bem-sucedida do plano em si pode manter o plano no caminho certo.

O plano pode incorporar:

- O escopo e os objetivos do plano;
- Elementos do caso de negócios, como cronograma estimado de implementação e necessidades de recursos;
- Detalhes específicos, mensuráveis, alcançáveis, realistas e de tempo;
- Uma descrição de como os objetivos da gestão de riscos se alinham com a missão e estratégia da organização;
- Uma declaração de compromisso da liderança com a gestão de riscos, incluindo uma discussão sobre a autoridade e as relações de relatório;
- Expectativas de como a organização integra a gestão de riscos em processos de governança, definição de estratégia, tomada de decisões e negócios-chave e processos operacionais;
- Um esboço de comitês de supervisão relevantes, órgãos governamentais e partes interessadas-chave e as expectativas e responsabilidades para cada um desses grupos. Isso pode incluir o conselho de administração, comitês de auditoria, comitês de risco, Alta Direção, chefes de departamento, proprietários de riscos, outros especialistas no assunto e partes interessadas organizacionais;
- Os recursos necessários para implementar o plano e integrar a gestão de riscos nas operações diárias e na tomada de decisões incluem:
  - Pessoas, habilidades, experiência e competência;
  - Recursos financeiros e tecnológicos necessários para apoiar o processo de gestão de riscos;
  - Processos e ferramentas para gerenciar, monitorar e relatar riscos;
  - Ferramentas para comunicação e consulta eficazes;
  - Métodos de gestão de mudanças; e
  - Treinamento de gestão de riscos e atividades de suporte que serão necessárias para integrar a gestão de riscos.
- Processos adequados para identificar, analisar e avaliar riscos e analisar a eficácia e eficiência dos tratamentos e controles de risco;
- Uma explicação de como os proprietários de risco são atribuídos, como os tratamentos de risco são priorizados e selecionados e como o desempenho contínuo é medido;

- Mecanismos de comunicação e relatório de risco para cada grupo, incluindo o formato de relatórios, sequência, gatilho, frequência e audiência;
- Procedimentos de escalonamento de risco definidos para resultados que não são usuais;
- Discussão da filosofia da organização sobre lições aprendidas e como essas oportunidades de crescimento são identificadas, avaliadas e incorporadas para apoiar a melhoria contínua e a maturidade de atividades de gestão de riscos ao longo do tempo; e
- Monitoramento e medição do desempenho contínuo.

2.7 Gestão de mudança organizacional

O plano de gestão de riscos pode incluir propostas de mudanças necessárias aos papéis de trabalho, estruturas organizacionais, processos e tecnologia. A aplicação de métodos de gestão de mudanças a essas mudanças aumenta seu provável sucesso.

Algumas pessoas aceitam voluntariamente a integração da gestão de riscos na tomada de decisões e outras atividades, enquanto outras resistem firmemente a ela. A antecipação e o gerenciamento de respostas potencialmente variadas podem ser considerados parte da integração do plano.

A gestão de mudanças geralmente envolve várias etapas. O passo fundamental para integrar a mudança e superar a resistência é desenvolver comunicações claras e convincentes em relação a:

- Natureza e escopo da mudança;
- Por que a mudança é necessária atualmente (qual é a urgência e o resultado previsto);
- Quem está patrocinando, apoiando e participando da mudança;
- Como a mudança desejada melhora a capacidade da organização (ou dos indivíduos resistentes) de atingir objetivos;
- Obstáculos que devem ser removidos para que a mudança possa ocorrer;
- Meios de reunir feedback e medir a adoção da mudança;
- Como a integração e os resultados bem-sucedidos são reconhecidos; e
- Consideração de como os métodos de gestão de mudanças organizacionais ajudam a resolver os desafios de comportamento humano dentro de qualquer abordagem de gestão de projetos ou integração.

Métodos diferentes de gestão de mudanças podem ser pesquisados e personalizados para uma organização, dependendo se a mudança é considerada incremental ou transformadora.

3. Processo de gestão de riscos

3.1 Introdução

Um processo estruturado de gestão de riscos visa alinhar a gestão de riscos com objetivos e gerenciar o risco de forma imparcial. Embora as etapas básicas do processo se apliquem a qualquer risco e a qualquer nível da organização, diferentes técnicas de avaliação de riscos podem ser usadas, dependendo das circunstâncias.

Um importante foco da gestão de riscos está na criação de valor para a organização e na melhor tomada de decisão. No entanto, em muitas circunstâncias, os riscos são bem conhecidos, e os controles estão implementados. Nesses casos, o foco da gestão de riscos pode ser a garantia de que os controles estão adequados, funcionam eficazmente e asseguram que este seja o caso.

3.2 Comunicação e consulta

Tomar uma abordagem inclusiva para a comunicação e consulta auxilia na identificação de riscos e na obtenção de aceitação e suporte efetivo para decisões sobre a significância e o tratamento de riscos.

As partes interessadas internas e externas precisam ser identificadas, e os planos precisam ser feitos para se comunicar e consultar com elas. Isso ocorre no início

do processo e em pontos apropriados durante todo o processo. Para qualquer avaliação de riscos, considerar qual a expertise necessária, quem deve estar ativamente envolvido e quem será mantido informado dos resultados. A consulta pode ocorrer em qualquer momento do processo em que a informação adicional melhore a compreensão dos riscos ou da confiança nas ações resultantes.

As partes interessadas devem ser identificadas e as estratégias de comunicação decididas, como:

- Fatores humanos e culturais podem ser uma fonte de incerteza;
- Parte interessadas têm o direito de saber se um risco pode afetá-las; e
  - As perspectivas das partes interessadas sobre o risco podem ser relevantes.

As seguintes perguntas podem auxiliar na determinação de uma consulta eficaz e eficiente das partes interessadas:

- Foram identificadas as partes interessadas internas e externas apropriadas antes do início do processo de gestão de riscos?
- As partes interessadas estavam devidamente engajadas em cada etapa do processo?
- Alguma parte interessada adicional foi identificada durante todo o processo de gestão de riscos?
- Quais partes interessadas foram consultadas durante a avaliação e o tratamento de risco?
- Houve comunicação com as partes interessadas apropriadas por toda parte?
- Os resultados da decisão ou do processo de gestão de riscos foram devidamente comunicados?
- Foram considerados os resultados exigidos pelas partes interessadas?

3.3 Definição do escopo e contexto da avaliação de riscos

O primeiro passo do processo de gestão de riscos é definir o escopo, o(s) limite(s) e o contexto. Isso assegura melhor aproveitamento do tempo, esforço e recursos da organização. Estabelecer o contexto inclui compreender o impacto que o contexto organizacional (ver 3.4.1, *Entender e usar o contexto organizacional*) possui na avaliação de riscos.

Todas as atividades da gestão de riscos precisam considerar os objetivos e valores organizacionais, bem como os objetivos específicos do processo de avaliação

de riscos. Objetivos estratégicos se traduzem em metas tanto financeiras quanto não financeiras, e contra as quais a organização mede o desempenho. Objetivos em diferentes níveis dentro de uma organização precisarão estar alinhados com os objetivos, valores e metas no nível da organização. As metas no nível da organização podem ser cascateadas para diferentes partes da organização de diferentes maneiras, para que as metas definidas sejam específicas para o trabalho realizado por unidades individuais. A realização combinada de metas em diferentes níveis de unidade ou departamento ajuda a atingir as metas organizacionais gerais.

EXEMPLO – Estudo de caso

A seguir, exemplos de contexto de avaliação de riscos.

Para avaliação de riscos no nível organizacional

- Mudança nos requisitos legais, como atualizações ou novas regulamentações de imigração ou requisitos fiscais restritivos, pode ser uma fonte de risco para uma organização que opera em vários países.
- A ação de um concorrente para adquirir entidades menores e reduzir o preço pode representar riscos para a sobrevivência de uma organização.
- Um projeto pode ter um objetivo relacionado ao cronograma desse projeto e à necessidade de identificar riscos que possam atrasar o projeto ou permitir que ele termine mais cedo. Em nível organizacional, o tempo de conclusão do projeto pode afetar objetivos relacionados ao lucro e à reputação.

Para avaliação de riscos no nível operacional

- Corte de custos descontrolado pode levar à falta de pessoal e resultar em maior risco de perda de produtividade das operações.
- Questões culturais, como uma cultura de culpa, podem levar a uma relutância em identificar, relatar e aceitar a responsabilização por riscos.

Informações relacionadas ao escopo e contexto são encontradas em conversas com pessoas e por referência a políticas, planos de negócios e outros documentos de toda a organização.

3.4 Definição dos critérios de risco

Os critérios de risco são um conjunto de regras ou declarações que permitem a tomada de decisões consistentes em toda a organização. O uso de critérios de risco suporta uma melhor tomada de decisão, como:

- Como é decidido que se um risco foi controlado suficientemente;
- Quando um risco é inaceitável então o trabalho tem que parar independentemente do benefício;

- Quando o benefício potencial é suficiente para tornar-se um risco aceitável;
- Como julgar a importância relativa dos riscos para a alocação de recursos;
- Quando informar mais níveis superiores da existência de riscos; e
- Como as trocas são feitas quando vários objetivos são afetados.

Os critérios de risco podem diferir para diferentes tipos de riscos e convém que sejam compatíveis com a exposição máxima de risco que a organização está disposta a ter. Uma organização pode definir critérios considerando suas prioridades, como, por exemplo, as três dimensões da sustentabilidade (ambiental, social e econômica).

EXEMPLO

- Organizações podem estabelecer metas para reduzir a pegada de carbono. Os critérios de risco levariam em conta ameaças e oportunidades relacionadas a esse objetivo.
- Uma organização pode declarar suas metas para os riscos à saúde e à segurança, para que não ocorram incidentes. Critérios de risco compatíveis com esta declaração esclareceriam se os riscos são controlados na medida do possível. Se mais controles forem viáveis, eles podem ser aplicados.
- Instituições financeiras podem estabelecer critérios com base no Valor em Risco (VaR). (O VaR de uma carteira é o valor financeiro máximo esperado para ser perdido ao longo de um determinado horizonte de tempo, em um nível de confiança predefinido).

Os critérios utilizados para comparar a significância relativa dos riscos a diferentes objetivos podem basear-se na consideração das consequências e na sua probabilidade. Uma escala comumente aplicada e relevante é necessária para medir e comparar riscos. Por exemplo, diferentes probabilidades, níveis e tipos de consequências podem ser considerados, utilizando-se uma escala qualitativa, semiquantitativa ou quantitativa. As consequências podem ser tangíveis ou intangíveis. Descrições que definem probabilidades, consequências e critérios de decisão devem ser inequívocas e permitir uma interpretação fácil. Convém que todas as suposições sejam explicitamente declaradas.

EXEMPLO

Em algumas situações, uma matriz ajuda a comparar diferentes tipos de riscos. A matriz tem consequências de um eixo, e probabilidade do outro. Cada risco é traçado na matriz de acordo com a probabilidade de suas consequências. Geralmente, quanto maior a combinação da probabilidade e consequência, maior é a prioridade ou maior é a necessidade de encaminhar o risco para níveis mais elevados na organização. A matriz também pode mostrar o lado positivo da avaliação de riscos com a pontuação, capturando o potencial impacto e a probabilidade de oportunidades. Riscos com maiores consequências podem merecer maior prioridade, devido à natureza da consequência. No caso em que uma consequência extremamente alta possa ser uma fatalidade, todos os esforços devem ser considerados para reduzir o risco, independentemente da probabilidade da falha.

NOTA: As matrizes podem ajudar a representar a importância relativa. No entanto, é necessário cuidado para assegurar que os métodos subjacentes utilizados para determinar conclusões sejam precisos e defensáveis.

Quando houver alta incerteza, como no planejamento estratégico de longo prazo ou em novas tecnologias, os critérios de risco predeterminados podem não ser apropriados. Nesses casos, as decisões sobre riscos associados a oportunidades e ameaças podem se beneficiar de consulta e discussão.

3.5 Avaliação de riscos

As incertezas permeiam todos os aspectos do contexto e das atividades de uma organização e podem ter resultados positivos, negativos ou neutros. Um resultado negativo para uma parte pode se tornar positivo para outra. Os riscos podem ser identificados para que possam ser considerados nas decisões e para que os tratamentos possam ser desenvolvidos para apoiar resultados positivos e reduzir os desfechos negativos.

A incerteza influencia indivíduos e organizações, incluindo tomadores de decisão. A percepção do risco é situacional, pois surge da incerteza sobre a compreensão ou conhecimento de um evento futuro. Isso inclui a incerteza sobre suas consequências para os objetivos e as características e variáveis envolvidas, incluindo a probabilidade de sua ocorrência.

A avaliação de risco abrange três etapas: 1) identificação de riscos (reconhecimento dos riscos), 2) análise de riscos (compreensão dos riscos) e 3) avaliação de riscos (julgamento da sua significância).

A abordagem utilizada precisa ser estruturada, coordenada e abrangente, bem como fazer uso das melhores informações disponíveis. A cultura organizacional e os vieses devem ser considerados na identificação e avaliação de riscos e na avaliação da eficácia dos controles.

Os objetivos e o cronograma de decisão determinam como os riscos são avaliados. Uma vez que estejam totalmente integradas à cultura de uma organização, as avaliações de riscos podem se tornar uma parte automática e informal do processo de tomada de decisão, quando as decisões forem simples e frequentes. Quando as decisões se tornarem mais significativas ou complexas, convém que um processo de avaliação de riscos deliberativo seja aplicado.

Nessas situações, podem ser utilizadas técnicas limitadas de avaliação de risco para chegar a uma decisão em um prazo reduzido. Quando as decisões forem estratégicas ou bastante complexas, convém que um esforço deliberativo mais rigoroso seja aplicado.

EXEMPLO – Estudo de caso

Como exemplo de resultados positivos e negativos, a chuva pode ser uma fonte de perda para um construtor, mas um ganho para um agricultor. O benefício da chuva para o agricultor é que as plantações existentes crescem melhor. A chuva também oferece a oportunidade de plantar mais sementes, se o agricultor optar por fazê-lo. No entanto, essa oportunidade é acompanhada pelo risco de não haver continuidade da chuva, e o custo das sementes será perdido. Por outro lado, a chuva pode atrasar o trabalho para a construtora, resultando em perda de tempo e dinheiro.

O risco depende da situação. O mesmo evento pode não ocasionar riscos em uma situação, mas ter riscos em outro contexto. Dependendo dos objetivos e valores, uma coisa pode representar um baixo risco para uma pessoa, bem como um alto risco para outra.

EXEMPLO

Uma árvore caindo na floresta não é um risco se ninguém estiver lá, mas se ela cair sobre uma trilha de fogo, ela representa um risco para aqueles que têm que usar a trilha de fogo. O nível de consequência depende do motivo para querer usar a trilha de fogo, ou seja, se tem fogo ou não.

O risco pode ser avaliado:

- Para novas atividades ou quando novos conhecimentos se tornarem disponíveis;
- Quando houver mudança significativa no contexto ou nos objetivos;
- Periodicamente, para refletir os resultados positivos e negativos atuais dos riscos já identificados e identificar quaisquer novos riscos;
- Quando os controles ou critérios de risco mudarem; e
- Ao tomar decisões que possam afetar os objetivos organizacionais.

3.5.1 Identificação de riscos

Uma vez que a consideração do risco diz respeito ao efeito da incerteza nos objetivos, o ponto de partida para identificação de riscos é considerar o que pode afetar os objetivos, tanto para a organização como para a parte para a qual a avaliação foi requisitada. Qualquer ameaça ou incerteza na realização desses objetivos pode justificar uma avaliação mais aprofundada.

Identificar a incerteza que pode afetar objetivos inclui uma variedade de considerações, por exemplo, o que é desconhecido, não compreendido, variável, mal interpretado ou conhecido, mas imprevisível. A incerteza pode surgir da imprevisibilidade inerente aos eventos naturais e à natureza humana, ou devido à nossa incapacidade de compreender totalmente a essência e a natureza humana. Circunstâncias novas, em mudança, complexas, caóticas, raras e remotas também são fontes de risco.

O risco também pode ser identificado reconhecendo coisas dentro da organização ou seu contexto, que podem levar ao risco (exemplos incluem riscos físicos, pressões organizacionais ou fraquezas em sistemas de gestão ou controles de risco). Existem muitas maneiras de identificar riscos, incluindo:

- Coletar informações históricas, analisando criticamente a experiência de outras organizações e consultando pessoas com experiência e expertise;
- Aplicar o pensamento imaginativo sobre o futuro; e
- Aplicar ferramentas sistemáticas de identificação, como diagramas espinha-de-peixe, análise do modo de falha e efeitos, técnica *what-if* estruturada e estudo de perigo e operabilidade, conforme descrito na ABNT NBR IEC 31010.
- Ao identificar e registrar o risco, é útil pensar nos riscos como cenários que representam o que pode acontecer no futuro.

- Também pode haver cenários em que uma fonte de risco possa ser identificada, mas o mecanismo pelo qual a fonte é capaz de afetar objetivos não seja. Em alguns casos, a natureza das consequências também pode ser desconhecida. Essas fontes de risco ainda podem ser gerenciadas, embora o risco não possa ser totalmente descrito ou medido.

3.5.2 Definição de categorias de riscos

Uma vez identificados os riscos, algumas organizações acham útil categorizá-los. Isso pode ser útil se o número de riscos for tão grande que se torne incontrolável. A categorização dos riscos pode permitir um melhor uso dos recursos, pois riscos semelhantes podem ser tratados em conjunto. Isso também ajuda a quebrar barreiras entre as unidades organizacionais e incentiva a comunicação e a compreensão. A classificação de riscos em categorias pode ajudar a identificar onde uma área de risco foi negligenciada.

As categorias utilizadas podem ser personalizadas para fazer sentido à organização, para serem comuns a toda a organização e expressas em termos claros e sem ambiguidades. A definição de riscos usando uma linguagem inconsistente em uma organização dificulta relacionar riscos comuns em diferentes departamentos e focar nos riscos mais importantes. Geralmente, as categorias representam os tipos de risco comumente encontrados. Categorias não podem limitar o pensamento na identificação de riscos, de forma que riscos raros e emergentes sejam incluídos.

Ver o Anexo B para obter exemplos de categorias de risco.

3.5.3 Análise de riscos

O propósito da análise de riscos é entender o risco. Isso inclui compreender as consequências para os objetivos, sua probabilidade, causas e controles existentes e, quando apropriado, obter um nível de risco. Esse entendimento pode ser usado para:

- Identificar opções de tratamento que funcionem;
- Comparar riscos com os critérios (ver 4.4, Definição dos critérios de riscos);
- Entrar em decisões que podem envolver múltiplos riscos; e
- Fornecer informações a serem utilizadas por diferentes partes interessadas na avaliação de riscos em seu contexto.

A análise de fontes de riscos com técnicas de causa-raiz pode identificar causas diretas e subjacentes. Analisando as causas, é possível verificar até que ponto as causas estão atualmente bem controladas. A análise dos controles existentes verifica se esses controles são eficazes. Juntos, fornecem informações sobre a necessidade de novos tratamentos ou para melhorias nos controles existentes.

A avaliação da eficácia do controle pode incluir as seguintes verificações ou testes:

- Controle é bem especificado – determinado por meio de uma análise crítica dos critérios da especificação;
- Controle existe e está operacional;
- Controle está funcionando conforme o planejado – é testado e observado na operação;
- Controle é confiável – é avaliado para possíveis desvios, falhas ou contornos;
- Controle é eficaz – funciona conforme o pretendido, quando requerido; e
- Controle é eficiente – é relevante, adequado e alinhado com os objetivos e circunstâncias atuais.

A forma como o risco é analisado depende da finalidade da análise e da natureza dos critérios contra os quais o risco deve ser avaliado.

EXEMPLO

- Identificar opções de tratamento, analisar as causas e controles existentes de um risco de segurança com critérios "até onde é razoavelmente prático" revela se é necessário tomar ação preventiva adicional.
- Observar se o risco de um experimento de destilação líquida inflamável é aceitável, simular e analisar os efeitos de uma explosão no pior cenário determina a eficácia dos arranjos de proteção contra explosão.
- Decidir se os riscos associados a uma excursão escolar nas montanhas são justificáveis pelo valor educacional, uma análise subjetiva de potenciais desfechos positivos e negativos da excursão leva em conta os controles planejados para implementação.

Em alguns casos, uma medida de risco é necessária para analisar o risco. Tradicionalmente, esta é uma combinação de consequências e de sua probabilidade. As consequências podem resultar de uma resposta ou falha em responder a uma oportunidade ou ameaça em relação aos objetivos.

As consequências podem ser descritas na forma de:

- Um ou mais resultados discretos, com cada um dos quais podendo ter uma possibilidade ou probabilidade associada; e

- Uma série de resultados muitas vezes na forma de uma função de distribuição ou densidade de probabilidade.

Qualquer cenário pode afetar múltiplos objetivos. Alguns cenários são uma cadeia de eventos em que as consequências se tornam fontes de outros riscos. As consequências também podem ter efeitos em cascata e combinados. Por exemplo:

- Eventos climáticos extremos podem resultar em mais incêndios florestais;
- Incêndios florestais podem resultar em danos aos sistemas de distribuição de energia e mais quedas de energia;
- Quedas de energia podem resultar em falha nos sistemas de ar-condicionado e em mais casos de estresse térmico; e
- Uma oportunidade nas frequentes quedas de energia pode abrir o mercado para geração solar local e armazenamento de eletricidade.

EXEMPLO – Estudo de caso

Por exemplo, um derramamento de um produto químico afeta inicialmente a produção como perda de produto e produção ou disrupção de negócios. Se o produto químico for perigoso, também há consequências para a segurança, e se o derramamento entrar na água subterrânea, há consequências para o meio ambiente. Dependendo da escala do derramamento, também pode haver consequências financeiras e para a reputação.

Uma medida de consequência pode ser qualitativa (por exemplo, uma descrição ou uma escala de classificação) ou quantitativa.

Em alguns casos, as saídas de um modelo financeiro ou técnico, ou de um relatório com informações descritivas ou quantitativas disponíveis podem ser as mais úteis para fornecer informações a um tomador de decisão sobre as consequências.

EXEMPLO

Exemplos de consequências representados pela quantificação incluem consequências financeiras, como produtividade e custo da receita. Consequências tangíveis, por vezes, quantificam medidas financeiras e físicas.

Consequências intangíveis são mais propensas a serem representadas qualitativamente, como satisfação do funcionário, satisfação do cliente, confiança ou reputação dos investidores. Às vezes, medidas quantitativas podem ser usadas para ilustrar consequências intangíveis. O uso de linguagem consistente e inequívoca é fundamental para a compreensão comum do risco.

Pode ser útil entender a probabilidade de qualquer um dos componentes de um cenário de risco (por exemplo, a probabilidade da fonte de risco existente, a probabilidade de um evento, a probabilidade de um controle falhar ou a probabilidade de uma consequência particular). A probabilidade que está sendo referida em qualquer instância precisa ser especificada.

Ao usar dados passados para estimar a probabilidade de uma determinada consequência, observar que o futuro não necessariamente segue o passado: porque algo ainda não aconteceu, não significa que é improvável que aconteça amanhã. Outras abordagens para estimar a probabilidade incluem previsões usando técnicas de modelagem e opinião de especialistas.

A probabilidade pode ser expressa como uma frequência (quantidade esperada de ocorrências em um determinado período) ou como uma probabilidade de ocorrência (expressa como uma razão, por exemplo, % de projetos ou % dos empregados). Geralmente, expressar a probabilidade como frequência é mais consistentemente compreendido.

A probabilidade de uma consequência se preocupa com a natureza das possíveis causas, com a eficácia dos controles existentes para essas causas e, em alguns casos, com a vulnerabilidade. Esses fatores precisam ser analisados antes que uma estimativa de probabilidade possa ser feita. A probabilidade e a consequência podem ser combinadas para representar o nível de risco. No entanto, todos os métodos para fazer isso, sejam qualitativos ou quantitativos, sofrem de um problema comum. Quando houver uma distribuição de consequências, nenhuma simples estatística válida (ou estimativa) representa a consequência. Às vezes, a média é usada, mas isso ignora raros eventos de alta consequência que podem ser de maior preocupação para a direção. O uso de consequências mais graves e críveis para a medida de risco ignora eventos comuns que, quando tomados em conjunto, podem ser altamente significativos em curto prazo.

A forma como a estimativa da magnitude de um risco é feita deve ser entendida, bem como incertezas e potenciais vieses na estimativa. Informações descritivas sobre a natureza das consequências e o que se sabe sobre sua probabilidade podem ser mais úteis para um tomador de decisão do que um nível consolidado de risco. A avaliação da detectabilidade pode ajudar na identificação de potenciais

riscos de baixo impacto e ajudar a decidir a alocação de recursos em medidas preventivas e corretivas versus detectivas. Por exemplo:

- A velocidade na qual o risco se materializa, também conhecida como velocidade de risco, pode adicionar importância à significância do risco. Se o impacto do risco for alto, com alta probabilidade de ocorrência e velocidade lenta, pode ser possível que uma organização tome medidas adequadas para reduzir o impacto. No entanto, se a velocidade for alta, então não haverá tempo suficiente para reagir, e o tratamento de risco pode variar.
- Detecção atribui peso adicional às medidas de risco. Perguntas que podem ajudar a explicar a capacidade de detecção incluem:
  - "Quão fácil ou difícil é detectar a ocorrência de um evento?"
  - "Temos tempo razoável para reagir antes da ocorrência do evento?"

A ABNT NBR IEC 31010 fornece mais informações sobre medidas de risco e seu uso. Se a análise for realizada por experts ou não, vieses e percepções podem influenciar o nível de risco estimado e como a aceitabilidade é interpretada. Devido ao nível de subjetividade envolvido, as organizações podem decidir se a obtenção de uma medida de risco é de valor para elas nas decisões que precisam ser feitas, ou se pode ser uma atividade demorada. Os riscos são analisados em intervalos apropriados e à medida que as condições mudam.

3.5.4 Avaliação de riscos

O objetivo do tratamento de riscos é melhorar os controles existentes ou, quando aplicável, criar novos controles. Isso envolve analisar criticamente as opções de melhoria e planejamento, implementação e análise crítica de quaisquer mudanças necessárias. Os resultados da análise de riscos podem ser comparados com critérios de risco para determinar a significância do risco. A compreensão do risco e sua significância são relevantes para qualquer decisão, incluindo:

- Tratar ou não um risco e as prioridades para as ações de tratamento;
- Como tratar riscos específicos;
- Como melhor alocar recursos para alcançar objetivos;
- Selecionar entre as opções que envolvam uma faixa de riscos e os custos e benefícios associados às compensações; e
- Se as recompensas ou resultados esperados de uma atividade superam os resultados negativos potenciais.

A análise de fontes e causas de risco, a gama de possíveis consequências e os controles existentes fornecem informações para as ações necessárias.

Ao avaliar um risco, todas as possíveis consequências e efeitos negativos e positivos são considerados, bem como potenciais ameaças e oportunidades. Oportunidades alinhadas com objetivos organizacionais que possam surgir de ameaças também podem ser avaliadas. As oportunidades identificadas durante a avaliação de riscos podem ser integradas aos processos de planejamento da organização. Ao avaliar oportunidades, a organização pode considerar os benefícios esperados para os objetivos, as incertezas e possíveis vieses na estimativa desses benefícios e as ameaças para alcançá-los.

3.5.5 Tratamento de riscos

O objetivo do tratamento de riscos é melhorar os controles. Isso envolve analisar criticamente as opções de melhoria e planejamento, e implementar e analisar criticamente as mudanças. Múltiplos tratamentos podem ser implementados, sozinhos ou combinados. Considerar todas as opções antes de selecionar tratamentos específicos pode resultar em resultados mais eficazes e eficientes.

As opções de tratamento de risco existentes podem ser aplicadas com ou sem modificações. Decidir a melhor combinação dos tratamentos é um processo iterativo que envolve consulta às partes interessadas e reavaliação do risco se os tratamentos propostos forem implementados. Os tratamentos devem ser práticos e acordados por aqueles que precisam implementá-los.

As opções podem incluir:

Opção de tratamento	Descrição
Evitar:	Remover a própria fonte de risco ou não realizar uma atividade, iniciativa ou projeto que possa produzir risco. Usar uma abordagem alternativa que elimine a fonte de risco e as consequências.

Opção de tratamento	Descrição
Compartilhar:	Compartilhar o risco com terceiros. Isso pode incluir transferência contratual, cauções e garantias, uso de seguros, títulos de desempenho ou outros instrumentos financeiros. Compartilhar o risco usando um contrato nem sempre transfere totalmente o risco; em muitas circunstâncias, um risco técnico é substituído por um novo risco associado ao desempenho contratual. Em algumas jurisdições, não é possível que certos riscos, como aqueles associados ao local de trabalho e à segurança, sejam transferidos sob circunstância alguma.
Modificar:	Realizar atividades que reduzam potenciais consequências negativas ou suas probabilidades e que aumentem potenciais consequências positivas ou suas probabilidades. Isso pode incluir precauções pré-perda, como reduzir a fonte de risco ou reduzir vulnerabilidades e medidas pós-perda para mitigar as consequências.
Mudar a probabilidade:	Por meio da aplicação de controles, arranjos organizacionais e procedimentos destinados a reduzir a frequência.
Mudar a consequência:	Verificar se os controles estão implementados e funcionando como esperado para modificar as consequências.
Reter:	Decidir aceitar o risco, planejando formas de agir caso ele ocorra, em vez de tentar influenciar a probabilidade ou o impacto. A aceitação ativa pode incluir o desenvolvimento de planos de contingência para responder se o evento ocorrer. A aceitação passiva significa não tomar ação alguma e lidar com as consequências, caso ocorram.
Explorar:	Realizar atividades que busquem maximizar as consequências positivas de um risco e suas respectivas probabilidades na obtenção de ganhos.

Reduzir a incerteza também pode reduzir o nível de risco. Por exemplo, as opções podem incluir a remoção de algumas das incertezas por meio de pesquisas ou fixação de um preço de compra futuro através da compra de futuros.

Após a consideração das opções de tratamento, a decisão pode exigir escalar para maior aprovação. Os indivíduos são, então, designados para ações e responsabilidades com cronogramas.

Embora seja importante ter um indivíduo responsabilizado por cada estratégia de tratamento, as organizações precisam considerar todas as partes interessadas no planejamento e na execução das estratégias de tratamento.

As análises de custo-benefício das opções de tratamento podem incluir custos de tratamentos de risco e custos associados a novos riscos decorrentes deles. Custos e benefícios podem ser expressos em termos sociais e ambientais, bem como em termos econômicos. Ameaças à implementação bem-sucedida de tratamentos, como resistência organizacional à mudança, podem precisar ser identificadas e tratadas.

Considerar se as consequências não intencionais de um tratamento de risco causam disrupção, complicações ou custos para a organização. Ao analisar criticamente e comparar uma estratégia de tratamento proposta e o risco residual à tolerância da organização ao risco, pode-se determinar a adequação do tratamento. Se o risco residual não for aceitável, então as opções de tratamento podem ser reconsideradas.

Os riscos podem ser diversos. Algumas fontes de riscos não estão sob o controle de uma organização e, apesar de uma avaliação rigorosa, alguns riscos podem ser esquecidos. Assim, as organizações podem precisar preparar planos para disrupções que afetam essas funções e ativos que são fundamentais para alcançar seus objetivos.

EXEMPLO – Estudo de caso

A produção em um *call center* de uma empresa de médio porte estava caindo abaixo dos níveis esperados. A causa provável foi identificada como aumento do absenteísmo. Por isso, o supervisor recomendou a atualização da política de absenteísmo para que os trabalhadores que faltaram muitas horas possam ser substituídos.

Antes de tomar qualquer ação, o chefe de Recursos Humanos solicitou que fosse feita uma avaliação de riscos para determinar se o curso de ação recomendado era apropriado. Foi realizada uma análise de causa-raiz que determinou que o alto absenteísmo era causado devido aos trabalhadores estarem constantemente doentes, com uma incidência acima do normal de infecção bacteriana. As infecções bacterianas foram mapeadas pela limpeza abaixo do padrão dos banheiros. Após uma investigação mais aprofundada, foi determinado que as razões para a limpeza abaixo do padrão eram a falta de treinamento da equipe de limpeza e os horários de limpeza reduzidos, como medida de contenção de custos pelo supervisor, alguns meses antes.

Para tratar o risco de doença dos funcionários que afetava os cronogramas de produção, a direção considerou várias possíveis opções de tratamento.

Opções de tratamento	Tratamento potencial
Evitar	Uso de apenas soluções baseadas em tecnologia – sem trabalhadores.
Transferir	Programa de terceirização para um fornecedor com um ambiente mais saudável.
Modificar	Melhoria da limpeza dos banheiros.
Reter	Aceite das condições como existem e verificação se os serviços de pessoal estão disponíveis no momento em que os trabalhadores estão doentes.
Explorar	Introdução de medidas preventivas de saúde.

A direção determinou que várias opções podem ser usadas para tratar o risco e decidiu tomar as seguintes ações:

Evitar: Investigar a tecnologia disponível para substituir os trabalhadores como uma solução de longo prazo.

Modificar: Depois de pesar o custo do aumento da limpeza do banheiro contra as consequências da perda de produção, a empresa voltou aos seus horários originais de limpeza. Adicionalmente, exigiu que o fornecedor treinasse o pessoal da limpeza, disponibilizasse desinfetante manual nas estações de trabalho e aumentasse a supervisão do contratante de limpeza.

Explorar: Pesquisar se uma clínica interna poderia fornecer serviços de tratamento e prevenção para melhorar a saúde geral dos trabalhadores e possivelmente atender à comunidade maior, como uma possível solução em médio prazo.

Em alguns casos, é necessário escalar as decisões para um nível mais alto na organização, para determinar se e como um risco deve ser tratado. Exemplos de quando podem ocorrer são quando um risco é considerado particularmente significativo, quando há ligações departamentais cruzadas que requerem uma decisão combinada ou quando os recursos necessários para o tratamento estão fora da autoridade do proprietário de risco.

A implementação de tratamentos pode resultar em risco residual. Se o risco residual não estiver dentro da tolerância da organização, o proprietário de risco pode considerar repetir o processo de avaliação e implementação do tratamento de risco.

Uma vez que um nível aceitável de risco é alcançado, a razão pela qual nenhum tratamento futuro é necessário deve ser registrada. Isso é o controle em si, proporcionando segurança às partes interessadas e auxiliando aqueles que analisam criticamente a avaliação de risco no futuro. A justificativa para nenhum tratamento adicional pode ajudar as organizações a enfrentar o viés comum de excesso de confiança na eficácia dos tratamentos de riscos.

3.5.6 Monitorar e analisar criticamente riscos

O processo de gestão de riscos é dinâmico. O contexto, os riscos e a eficácia dos controles podem mudar. Indicadores críticos de mudanças podem ser identificados e monitorados. A análise crítica regular dos riscos ajuda a incentivar a melhoria contínua. As ações de tratamento precisam ser continuamente monitoradas e reportadas à direção periodicamente e após qualquer evento de gatilho. A eficácia e a eficiência das operações de tratamento podem ser analisadas criticamente e verificadas por meio de critérios de desempenho e de análises de riscos atualizadas. Atrasos ou desvios na implementação de estratégias de tratamento podem ser rastreados e relatados às partes interessadas periodicamente, para assegurar a implementação oportuna.

3.5.7 Registrar e relatar riscos

O registro do risco em um repositório centralizado, por exemplo, em um registro de riscos ou sistema de informações, facilita a disseminação pela organização

e permite transparência quanto à gestão dos tratamentos propostos. Um plano de tratamento de riscos que atribui responsabilizações e cronogramas pode fazer parte do mesmo sistema de informações ou, no caso de um sistema baseado em papel, pode ser um documento separado. A necessidade de análise histórica de dados e a avaliação futura de tendências determinam os cronogramas de retenção de dados. O registro e o relato de mudanças significativas no risco são benéficos.

O registro inclui a observação de alterações nas informações, como modificações na implementação do tratamento e nos controles existentes e mudanças prioritárias. É importante que os riscos e suas causas não sejam confundidos no processo de documentação. Alguns riscos podem precisar ser registrados de forma específica, que é inconsistente com outros riscos.

4. Eficácia do programa de gestão de riscos

A excelência na gestão de riscos requer que as organizações avaliem periodicamente a eficácia de programas e atividades de gestão de riscos e sua integração na tomada de decisões. O escopo da avaliação pode ser personalizado para atender às áreas críticas de necessidade. Ele requer a compreensão da aplicabilidade do escopo de uma variedade de métodos de avaliação diagnóstica. Não há um único método-padrão para avaliar a eficácia de programas de gestão de riscos nas organizações. Qualquer que seja o processo ou método escolhido, ele precisa ser adaptável às mudanças na organização.

Vários métodos externos ou internos podem ser usados para determinar sistematicamente a eficácia do programa de gestão de riscos da organização. Estes métodos incluem modelos, processos, revisões e auditorias. Encontrar a combinação apropriada de métodos é fundamental para obter resultados bem-sucedidos. O objetivo dessas avaliações é identificar pontos fortes, sucessos, *gaps* e áreas de melhoria. Esses tipos de avaliações também podem identificar áreas em que os recursos de gestão de riscos não estão atendendo às expectativas das partes interessadas.

4.1 Métodos externos

Métodos externos podem incluir:

- *Benchmarking* – *Benchmarking* envolve a medição do desempenho de uma organização contra padrões externos de referência que frequentemente vêm

de organizações semelhantes fazendo coisas semelhantes. Isso pode começar com a identificação de pares para as práticas comuns, por meio de uma análise do setor e de segmentos relevantes do mercado. *Benchmarking* de uma organização com pares, por meio de pesquisas ou publicações comerciais ou associações disponíveis, pode revelar *gaps*, pontos fortes e fracos, diferenciais e riscos particulares. As organizações descobrem percepções adicionais comparando fatores de risco observados nos relatórios financeiros dos concorrentes, bem como os de parceiros do setor, com os seus próprios.

- Modelos de maturidade – Os modelos de maturidade são um conceito de medição para demonstrar o progresso do desenvolvimento e para destacar resultados consistentes entre as organizações. Modelos de maturidade de gestão de riscos incorporam critérios de gestão de riscos em relação a pessoas, cultura, processos, estruturas e tecnologia. Os usuários pontuam sua organização novamente a esses critérios, para fornecer-lhes informações sobre as áreas de força e melhoria em suas práticas e processos de gestão de riscos. Essas informações podem auxiliar no foco no desenvolvimento dos planos de melhoria dos programas de gestão de riscos.
- Publicações – Grupos industriais, reguladores, associações e acadêmicos publicam pesquisas e artigos instigantes sobre tendências e abordagens para a gestão de riscos. Esses trabalhos podem abranger estruturas, integração, técnicas, práticas e competências de gestão de riscos em organizações bem-sucedidas. Pesquisar, sintetizar e priorizar práticas ativamente no contexto da organização em análise é um meio de avaliar a eficácia de suas práticas e fornecer ideias para o desenvolvimento dos planos de implementação do programa de gestão de riscos.
- *Networking* – As técnicas de *networking* podem ser formais ou informais, e podem ser gerais ou mais especificamente focadas em uma área de melhoria.
  - As análises críticas por pares de programas são *networking*, que é uma técnica de avaliação que pode ser limitada em escopo por setor, tamanho ou região. Embora o pesquisador normalmente facilite uma avaliação por meio de reuniões presenciais, avaliações de *networking* também podem funcionar por reuniões virtuais ou pesquisas.
  - Eventos de *networking*, como conferências, cúpulas, reuniões da indústria e *workshops*, podem fornecer *insights* sobre as melhores práticas

e comparações de programas. Esses eventos podem ser presenciais ou virtuais.

4.2 Métodos internos

O sucesso dos programas de gestão de riscos pode ser avaliado determinando se as ferramentas são usadas e se materiais escritos são gerados, por meio de análises críticas com as partes interessadas e pelo uso de métodos de autoavaliação. Uma amostra desses métodos pode incluir:

- Mapeamento – O mapeamento pode ser usado como uma representação gráfica de um procedimento, processo, estrutura ou sistema que retrate o arranjo e as relações entre seus diferentes componentes e fluxo de informações, pessoas e atividades. Este método pode ser útil para a compreensão das atividades, pessoas e competências já presentes e disponíveis dentro da organização. Ele também informa os planos de implementação do programa de gestão de riscos para potencial colaboração com áreas de negócios e processos existentes.
- Pesquisas internas e entrevistas – Podem ser utilizadas entrevistas e pesquisas estruturadas para coletar informações sobre a eficácia e o valor do programa de gestão de riscos.
- Análises críticas internas de auditoria – A auditoria interna fornece ao conselho e à direção uma avaliação objetiva e independente da eficácia do programa de gestão de riscos de uma organização, determinando:
  - Se há evidências de que os riscos para a organização estão apropriadamente gerenciados de forma contínua, usando *feedback* como parte de melhoria contínua, e
  - Se há evidências de que os princípios foram aplicados.

Informações de relatórios de auditoria interna ajudam a determinar se os riscos são adequadamente manuseados em uma base contínua.

- Revisão periódica – Este método oferece a oportunidade de revisar o continuamente programa. A discussão pode incluir as principais partes interessadas e examinar os resultados com a intenção de identificar sucessos, problemas e áreas que precisam ser melhoradas. Trata-se de uma ferramenta eficaz para articular lições aprendidas e melhoria contínua.

- Evidências de integração dos princípios e estrutura da ABNT NBR ISO 31000 – Os princípios descrevem as principais qualidades dos programas de gestão de riscos. São utilizados para validar a eficácia do programa de gestão de riscos, documentando evidências para cada princípio. As evidências podem descrever especificamente como cada princípio é aplicado dentro da organização. Os elementos da estrutura fornecem detalhes sobre como o programa de gestão de riscos é integrado, projetado, implementado, avaliado e melhorado. Cada elemento descreve componentes e atributos que são medidos e avaliados.
- Análise crítica de processos e competências de gestão de riscos – Processos de gestão de riscos envolvem partes interessadas, avaliam e tratam riscos e relatam resultados, quando aplicados a decisões, projetos, atividades e áreas de atuação. A aplicação de critérios ou perguntas consistentes a esses processos ajuda as organizações a desenvolver processos consistentes e eficazes em toda a organização. As perguntas de análise crítica podem incluir:
  - O processo geral de gestão de riscos foi eficaz e útil?
  - Os líderes eram suficientemente hábeis?
  - As partes interessadas certas estavam devidamente engajadas?
  - Foram aplicadas técnicas adequadas de avaliação de riscos durante o processo?
  - Quais são as lições aprendidas e como agir sobre elas?
  - Avaliação dos resultados reais em relação à quantidade de risco que a organização está disposta a buscar para alcançar um objetivo (apetite ao risco) ou tolerar (tolerância ao risco).
  - Há evidências de que os princípios foram aplicados?

Um ou mais métodos internos ou externos podem ser usados para identificar e avaliar *gaps* e áreas de melhoria. Um plano de melhoria contínua pode então ser desenvolvido e implementado para enfrentá-los.

5. Melhoria contínua

5.1 Introdução

Uma gestão eficaz de riscos permite que a organização atinja seus objetivos ao avaliar continuamente os riscos para reduzir surpresas e melhorar o desempenho. É requerido que a gestão de riscos, como outros processos organizacionais, seja analisada criticamente contra os benefícios e objetivos que foram apresentados como parte do caso de negócio incluído na Seção 3 deste *handbook*.

As seguintes perguntas podem ajudar a determinar se a introdução ou atualização da gestão de riscos foi bem-sucedida. Por exemplo, a gestão de riscos:

- Forneceu benefícios para a organização na construção e manutenção de uma vantagem competitiva?
- Auxiliou no alcance dos objetivos da organização?
- Foi integrada nos principais processos da organização que auxiliam no alcance dos objetivos gerais?
- Melhorou o desempenho em direção à inovação?
- Identificou e considerou os riscos emergentes?
- Foi eficaz na avaliação e melhoria da preparação para disrupções?

A melhoria contínua na gestão de riscos é alcançada pela definição de metas de desempenho e pela medição e análise crítica regular do progresso.

O sistema de gestão de desempenho existente na organização pode ser usado para a melhoria contínua da gestão de riscos. Isso pode envolver:

- indicadores de desempenho para gestão de riscos alinhados com indicadores de desempenho organizacional e submetidos à análise crítica periodicamente para adequação;
- Medir o desempenho da gestão de riscos em relação aos indicadores de desempenho; e
- Periodicamente, efetuar análise crítica, se o plano de implementação, a estrutura e os processos da gestão de riscos continuarem sendo apropriados e se estiverem sendo seguidos durante as mudanças organizacionais.

5.2 Medição da melhoria da gestão de riscos usando indicadores-chave de desempenho

Uma possível ferramenta que uma organização pode usar para medir o sucesso da gestão de riscos são os indicadores-chave de desempenho (*key performance indicators* – KPI). É importante que os indicadores de desempenho sejam definidos na fase de planejamento, com base nas metas da organização.

Os KPI devem ser adequados para comunicar o desempenho da gestão de riscos interna e externamente.

Questões importantes que podem ser consideradas durante a medição da melhoria incluem:

Pergunta	Indicador-chave de desempenho (KPI)
As responsabilidades pelo risco são tratadas em todos os níveis?	Número de descrições de funções que incluem responsabilidades de gestão de riscos.
Existe treinamento em gestão de riscos disponível nos níveis requeridos dentro da organização?	Treinamento realizado de acordo com uma matriz de competência.
Os tratamentos estão concluídos a tempo?	Cronogramas de tratamento cumpridos.
As atividades de risco são tratadas no nível necessário?	Riscos reportados à liderança e ao Conselho

Pergunta	Indicador-chave de desempenho (KPI)
A melhoria contínua do processo de gestão de riscos é totalmente comunicada às partes interessadas internas e externas?	Relatórios internos de risco; relatórios de risco externo, conforme necessário.
A integração na estratégia organizacional e na gestão de riscos foi bem-sucedida?	A medição da redução de incerteza impactando os objetivos organizacionais
Os benefícios de introduzir, fazer a transição ou atualizar a abordagem de gestão de riscos têm sido realizados?	Comparação do processo de gestão de riscos da organização com as 'melhores práticas'
Houve articulação e progresso para o nível desejado de maturidade de risco?	Rastreamento dos cronogramas e entregas em relação ao planejado

5.3 Lições aprendidas

As organizações comprometidas com a melhoria contínua considerarão incorporar as lições aprendidas. Essas lições comunicam conhecimentos adquiridos pela experiência para alavancar informações benéficas no planejamento, processos de trabalho e atividades no futuro. As organizações podem incorporar informações de fontes externas e internas.

As metas, objetivos, papéis, responsabilizações e competências da organização podem mudar. Uma estrutura para gestão de riscos pode passar por várias iterações ao longo do tempo, evoluindo também os processos. É importante avaliar com precisão o progresso e o desempenho da implementação da gestão de riscos e aplicar as lições aprendidas, para continuar a criar e agregar valor à organização. Para qualquer metodologia que seja usada para capturar as lições aprendidas na gestão de riscos, é importante identificar ou perguntar:

- O que correu bem?
- O que não foi bem ou teve consequências não intencionais?
- O que poderia ser feito diferente na próxima vez?
- Os objetivos no caso de negócios foram alcançados?

- Os KPI foram alcançados?
- Todos os novos processos estão documentados?
- O sucesso foi comunicado e celebrado?

Anexo A

Exemplo de análise de *gaps* (*gap analysis*)

Os critérios de gestão de riscos variam de organização para organização. Este gráfico ilustra que pode não ser possível, ou mesmo desejável, preencher todos os *gaps* que são descobertos durante a análise. Por exemplo, as unidades de negócios avaliadas podem não estar contribuindo igualmente para o desempenho da empresa, ou os ambientes em que cada uma das unidades de negócios opera podem ser de complexidade e níveis de riscos variados. Portanto, o esforço e os recursos necessários para preencher completamente todos os *gaps* analisados podem não ser justificáveis.

Figura A.1

Critérios acordados para as práticas de gestão de riscos (fatores de sucesso)	Liderança sênior	Áreas funcionais (por exemplo, *compliance*, auditoria interna, segurança, planejamento etc.)[a]	Unidade de negócios 1	Unidade de negócios 2	Unidade de negócios 3
Compromisso da liderança/líder responsabilizado	●→●	●→●	◑→●	◔→●	○→●
Política/ orientação	●→●	●→●	●→●	●→●	●→●
Integrado no desenvolvimento de estratégia	◔→●	○→◑	◑→●	◑→●	◑→●
Integrado na realização de iniciativas estratégicas (desempenho)	●→●	◑→●	○→●	○→●	○→●
Integrado nas operações e decisões cotidianas	◑	●→●	●→●	◑→●	●→●
Integrado em relatórios de desempenho	◑→●	◑→●	◔→◑	○→◑	◔→◑
Competências do pessoal para avaliação de riscos	◑→◑	●→●	◑→●	○→◑	◔→◑

Chave

● Pequeno gap ◑ Gap parcial ◔ Grande gap ○ Gap crítico → Do estado atual para o estado futuro

[a] As áreas funcionais podem ser avaliadas por análises de gaps individuais, utilizando os mesmos critérios de desempenho da gestão de riscos.

Anexo B

Exemplo de categorias de risco

Os riscos dentro das seguintes categorias podem impactar os objetivos e a reputação da organização de forma positiva ou negativa.

O exemplo abaixo é apenas ilustrativo. Não se pretende servir para todas as organizações nem ser exaustivo. As organizações devem se apoiar em seus próprios líderes de risco na construção de categorias de risco e suas descrições.

Financeiros	
Mix de ativos	Capacidade de manter a carteira de ativos mais vantajosa financeiramente
Inflação	Aumentos incontroláveis nos níveis gerais de preços de bens e serviços nas principais economias
Crédito	Possibilidade de perda decorrente da falha do tomador em pagar um empréstimo ou cumprir obrigações contratuais
Mercado	Possibilidade de perdas de investimentos devido a fatores sistêmicos que afetam o desempenho geral dos mercados financeiros
Marca	Capacidade de construir e manter posição superior, reconhecimento da marca e conotação de qualidade para influenciar os consumidores a comprar seus produtos ou usar suas ofertas de serviços

Operacionais	
Pessoas	
Perigo	Possibilidade de danos ou prejuízos a partes interessadas, incluindo clientes, empregados e públicos
Planejamento sucessório	Processo formal e plano que identifica sucessores para posições-chave do conselho, executivas e operacionais
Desenvolvimento de talentos e satisfação dos empregados	Capacidade de proporcionar satisfação no trabalho e avanços na carreira, apoiando o crescimento pessoal e o desenvolvimento de oportunidades desafiadoras e dinâmicas, mentoria
Tecnologia	
Disponibilidade de dados	Acesso às informações necessárias em momentos críticos para desempenhar funções de trabalho, fortalecendo assim a continuidade de negócios, operações e processos
Integridade dos dados	Informações corrompidas, incompletas ou imprecisas por falhas nos controles de entrada e tratamento (ou seja, não devidas a erro de entrada manual) afetam negativamente aplicativos, sistemas e saídas, limitando a capacidade de tomada de decisão da gestão
Violação de dados/ privacidade	Riscos e incertezas associadas ao roubo em larga escala ou perda de informações e segurança de dados
Infraestrutura tecnológica	Riscos associados aos sistemas de informação e telecomunicações e à infraestrutura a eles relacionada. Consistência e confiabilidade da tecnologia em toda a organização, para apoiar os requisitos de informação do negócio, atuais e futuros, em um método eficiente, econômico e bem controlado
Propriedade e processo	
Disrupção de negócios	Perigo significativo, natural ou fabricado, que pode impedir operações principais
Propriedade intelectual	Riscos associados à identificação, proteção e segurança dos ativos de capital intelectual da organização e à gestão do uso da propriedade intelectual de terceiros
Disrupção do processo de negócios	Riscos associados à disrupção de processos de negócio necessários para atingir objetivos, como: ► Estratégia e relacionamento com clientes (*marketing*) ► Qualidade, melhoria de processos e gestão de mudanças ► Análise financeira, relatórios e gestão de capital ► Aquisição de clientes (vendas) ► Desenvolvimento de produtos ► Produção/prestação de serviços ► Contabilidade ► Abastecimento e aquisição/compras
Dependências de fornecedores	Transformação, execução e supervisão de entregas por fornecedores e organizações aliadas quanto à qualidade esperada dentro dos resultados financeiros esperados
Meio Ambiente	
Danos ambientais	Impactos no ambiente biológico ou físico
Danos ao ecossistema	Danos a longo prazo ou permanentes a um ecossistema

Estratégicos	
Marca	Capacidade de construir e manter posição superior, reconhecimento da marca e conotação de qualidade para influenciar os consumidores a comprar seus produtos ou usar suas ofertas de serviços
Modelo de negócios	Capacidade de reconhecer e inovar os elementos essenciais necessários para entregar com sucesso valor aos clientes existentes e potenciais de uma organização
Concorrência	Capacidade de reconhecer e reagir às ações, produtos e serviços dos concorrentes
Mudanças demográficas	Capacidade de planejar e adaptar-se às mudanças na demografia da população que impactam a demanda pelos produtos ou serviços da organização
Inovação/tecnologia disruptiva	Capacidade de planejar e adaptar-se a inovações que criam um novo mercado e rede de valor e, ao final, interrompem um mercado e rede de valor existentes, deslocando empresas líderes de mercado estabelecidas, produtos e alianças
Incerteza econômica	Flutuações na economia que aumentam ou diminuem a demanda por produtos e serviços da organização; capacidade de planejar e lidar com a possibilidade de períodos de recessão prolongados nos mercados em que a organização opera
Regulatório	Leis ou regulamentos que regem a conduta, o comportamento ou as ações das operações da organização. Riscos políticos e de mídia relacionados ao poder, influência ou controle dos esforços governamentais ou de lobby que afetam a organização

Bibliografia

Documentos ISO

- ABNT NBR ISO 31000:2018, *Gestão de riscos – Diretrizes*
- ABNT NBR IEC 31010:2021, *Gestão de riscos – Técnicas para o processo de avaliação de riscos*
- ABNT NBR ISO 31073, *Gestão de riscos – Vocabulário*

Toda organização enfrenta riscos que podem impactar seus objetivos. A gestão de riscos é a prática de usar processos, métodos e ferramentas para gerenciar esses riscos. Assim, as organizações que identificaram os riscos e se comprometeram com a gestão eficaz desses riscos estarão mais bem preparadas para lidar com eles. Este *handbook* foi desenvolvido para fornecer informações valiosas sobre como implementar a ABNT NBR ISO 31000, *Gestão de riscos – Diretrizes* e apoiar o esforço de uma organização na criação e proteção de valor.

International Organization for Standardization
ISO Central Secretariat
Ch. de Blandonnet 8
Case Postale 401
CH – 1214 Vernier, Geneva
Switzerland

iso.org

Associação Brasileira de Normas Técnicas
Rua Conselheiro Nebias, 1131
Campos Elíseos
01203-002
São Paulo – SP
Brasil

abnt.org.br

© ISO 2021 - © ABNT 2023
Todos os direitos reservados
ISBN 978-85-07-09583-5